DG INTERNS HUB

Cybersecurity Internship Program

WEEK 8

ADVANCED VAPT
Attack Surface Mapping, Parameter Testing & Attack-Chain Analysis

Prepared By: Prakhar Gupta

Role: Cybersecurity Intern

Submission Date: 28 October 2026

1. Executive Summary

This report documents Week 8 practical work for DG Interns Hub's cybersecurity internship. The assessment used the intentionally vulnerable DVWA application hosted locally at http://127.0.0.1:8080 and Burp Suite Community Edition to observe requests, replay requests, compare normal and modified inputs, and review application behavior.

The strongest confirmed result was observed on DVWA's SQL Injection page at the Medium security setting. A normal user ID returned one user record, while a modified input using the Boolean expression "2 OR 1=1" returned multiple user records in the lab. This indicates that the tested input could alter SQL query logic in this deliberately vulnerable application.

The Brute Force page was mapped as an authentication-related attack surface. A captured request showed username and password fields in the URL query string; this is an observed design concern, but the screenshot alone does not establish a successful brute-force attack or successful authentication. The Weak Session IDs page generated a new dvwaSession cookie after requests. The captured values changed, but the available evidence is not sufficient to conclude that the values are predictable or exploitable.

All tests were performed against the local training application. Findings should not be interpreted as evidence about any external or production system.

2. Objectives

- Map selected application functions and identify input points relevant to security testing.
- Capture and inspect HTTP requests and responses with Burp Suite.
- Compare baseline, valid, invalid, and modified SQL input behavior.

- Review authentication-related request handling and session-token behavior.
- Describe realistic impact, limitations of the evidence, and remediation measures.
- Maintain an evidence-based report without claiming unverified exploitation.

3. Scope, Environment and Methodology

3.1 Scope

In-scope target: the local DVWA instance at 127.0.0.1:8080. The tested pages shown in the supplied evidence include SQL Injection, Brute Force, and Weak Session IDs. No external target was tested as part of the screenshots included in this report.

3.2 Tools and environment

- Damn Vulnerable Web Application (DVWA), a deliberately vulnerable websecurity training application.
- Burp Suite Community Edition, used to capture, inspect, and replay HTTP requests.
- Web browser, used to navigate the DVWA pages and submit test inputs.
- DVWA security setting visible in the evidence: Medium for the SQLi and Brute Force page captures.

3.3 Method

The workflow was to identify an application page, submit a normal request, inspect the request and response in Burp, change one input at a time where appropriate, replay the request, and compare the returned content. Screenshots were retained as evidence. This is a limited manual assessment, not a complete automated or comprehensive penetration test.

3.4 Limitations

The supplied screenshots do not demonstrate a full end-to-end attack chain, successful brute-force authentication, IDOR, account takeover, or compromise of a real system. The Weak Session IDs evidence shows changing cookie values but does not establish whether the values are cryptographically unpredictable. Conclusions are therefore limited to the behavior directly visible in the evidence.

4. Attack Surface Mapping

Attack surface mapping identifies application functions and the inputs or state that may affect security. The following routes were visible in the DVWA navigation or captured traffic:

- SQL Injection: /vulnerabilities/sqli/ — user ID parameter submitted to a database-backed lookup.
- Brute Force: /vulnerabilities/brute/ — username and password parameters used by an authentication test page.
- Weak Session IDs: /vulnerabilities/weak_id/ — a Generate action sets a dvwaSession cookie.
- Shared application state: PHP session cookie and DVWA security-level cookie were present in the captured requests.

The mapping provides a starting point for further logic-based testing. It does not mean every listed page is vulnerable at every security level.

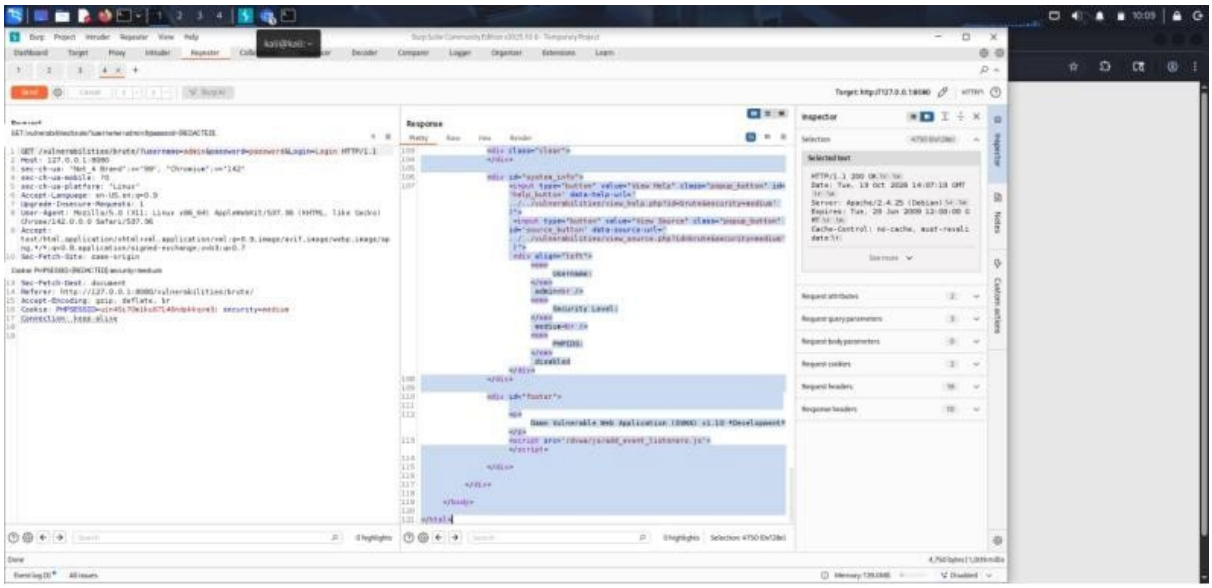


Figure 1. Brute Force Page Assessment

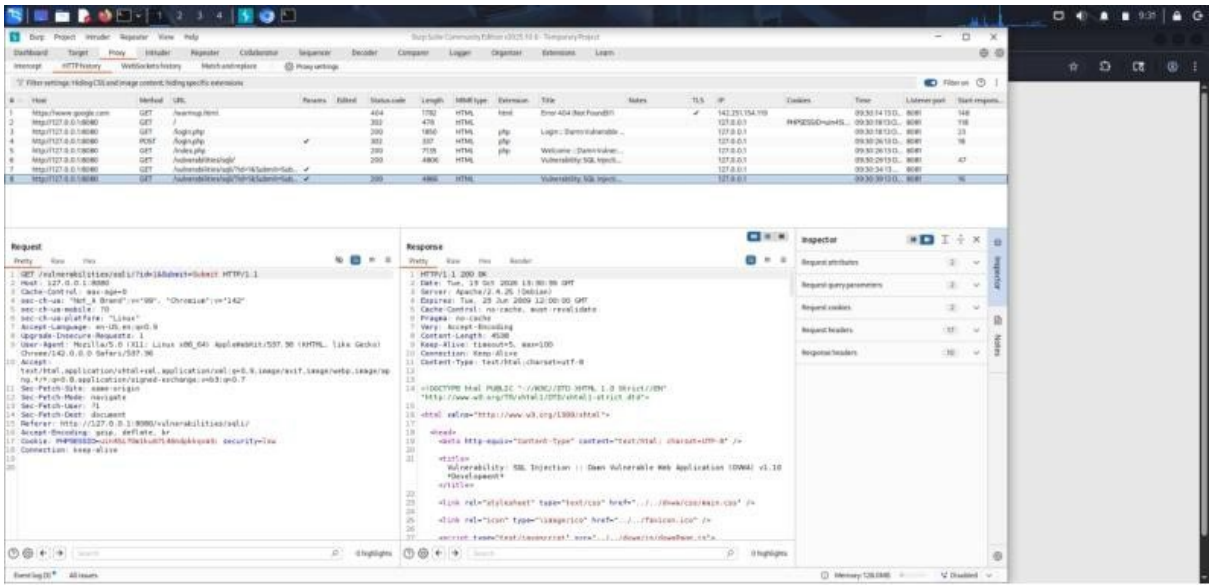


Figure 2. Capturing DVWA HTTP Requests Using Burp Suite

5. SQL Injection Parameter Testing

5.1 Baseline request

A baseline request was sent to the SQL Injection page with user ID 1. The response returned HTTP 200 OK and displayed the record for admin. This established expected behavior for a normal input.

5.2 Invalid parameter test

The user ID 999 was submitted as an invalid/non-matching identifier. The response was HTTP 200 OK, but no matching user record was displayed. This result is consistent with a lookup that has no matching record and is not, by itself, evidence of a vulnerability.

5.3 Valid parameter test

The user ID 2 returned the record for Gordon Brown. This confirmed that a normal valid identifier produced a single corresponding record.

5.4 Modified logic test

In Burp Repeater, the user ID value was changed to the URL-encoded expression “2 OR 1=1”. The server returned HTTP 200 OK and the response displayed five user records rather than only the requested record. The result indicates that the supplied value altered the SQL query logic in the tested DVWA configuration.

Observed impact in this lab: multiple user records were disclosed in the response. The evidence does not show password disclosure, account takeover, database modification, or impact beyond this local training application.

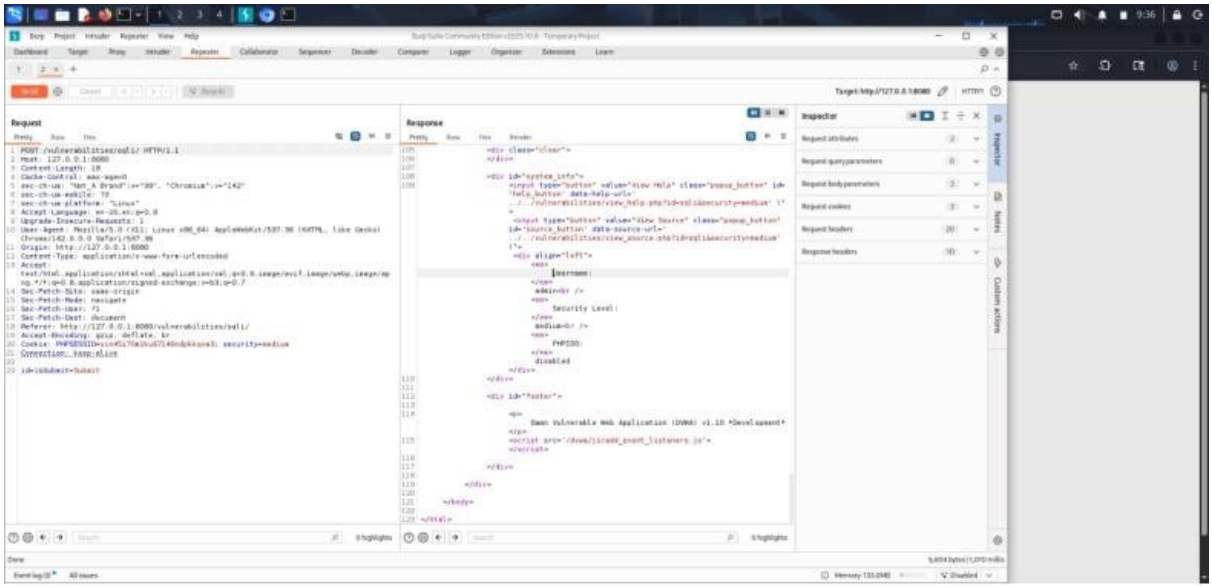


Figure 3. Baseline POST Request and Response in Burp Repeater

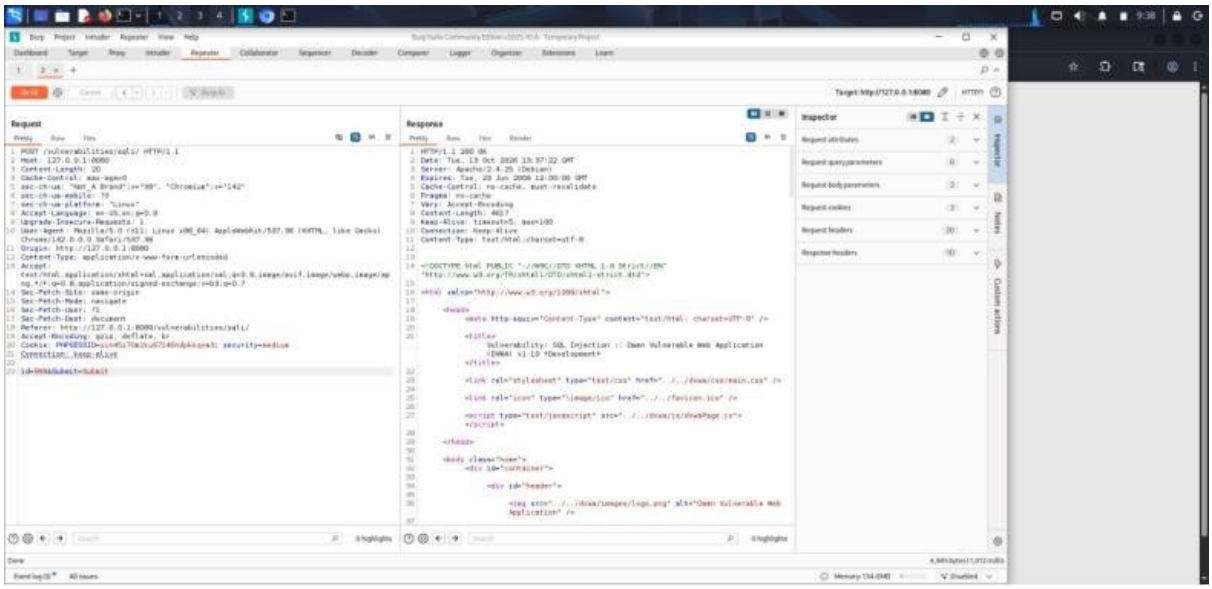


Figure 4. Invalid User ID Parameter Validation Using Burp Repeater

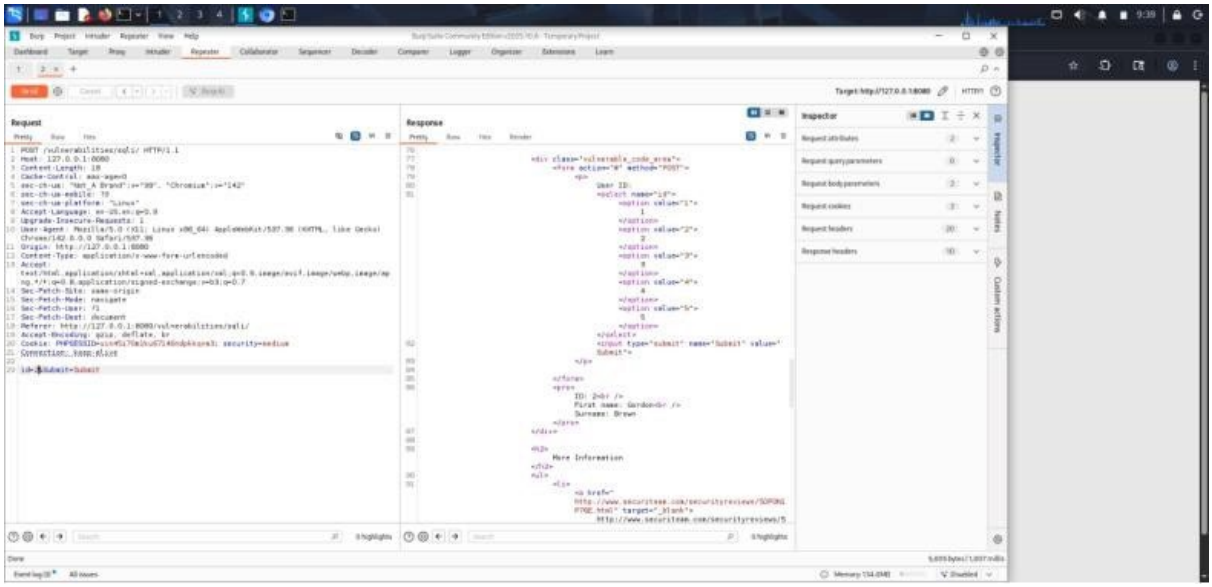


Figure 5. Valid User ID Testing Using Burp Repeater

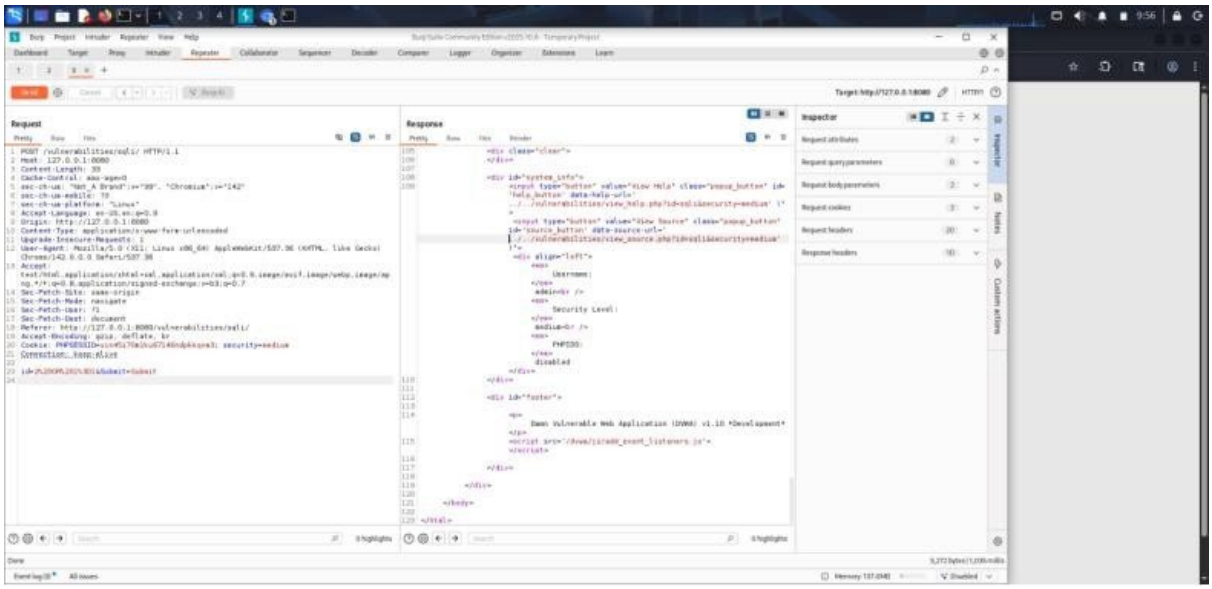


Figure 6. SQL Injection Demonstration at DVWA Medium Security Level

6. Authentication Attack Surface – Brute Force Page

The Brute Force page contains username and password fields. The captured request used the GET method and placed the username and password in the query string. The server returned HTTP 200 OK and the response showed the page's HTML and application status area.

Security observation: credentials in URL query strings may be recorded in browser history, web-server logs, proxy logs, screenshots, or other systems that process URLs. HTTPS does not prevent URLs from being stored in browser history or logs, so credentials should not be sent in URLs. The supplied evidence does not prove that a brute-force attempt succeeded or that rate limiting is absent.

• Use POST for credential submission and HTTPS for all authentication traffic.

- Avoid logging passwords and redact credentials from diagnostic records.
- Apply rate limiting, progressive delays, and monitoring for repeated failed logins.

- Use multi-factor authentication where appropriate and return generic login errors.

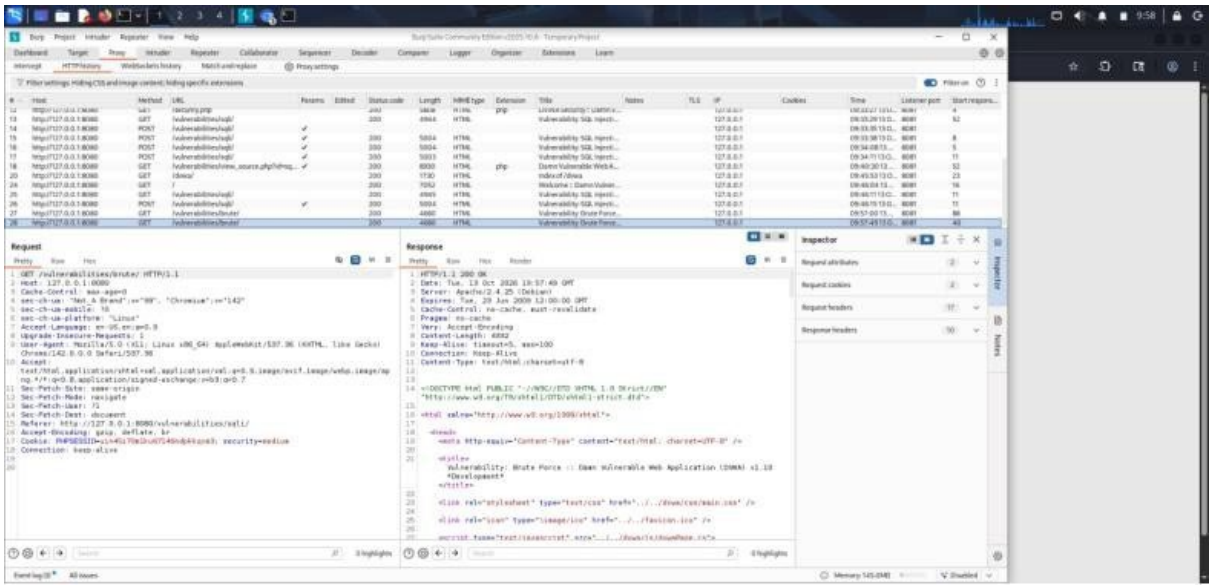


Figure 7. Attack Surface Mapping – Brute Force Login Functionality

7. Weak Session ID Observation

The Weak Session IDs page states that it sets a new cookie named dvwaSession when the Generate button is clicked. The captured POST request had an empty body, and the response returned HTTP 200 OK with a Set-Cookie header assigning a new dvwaSession value. Subsequent screenshots show more than one generated value.

This confirms that the page issues a changing token value. A changing value alone does not establish weakness: predictability requires a larger sample and analysis of the token-generation algorithm or sufficient statistical evidence. The report therefore records this as an observation requiring further validation, not a confirmed exploitable session-token vulnerability.

- Generate tokens using a cryptographically secure random-number generator.
- Use sufficiently long, unpredictable session identifiers.

- Rotate session identifiers after authentication and privilege changes.
- Set appropriate cookie attributes such as HttpOnly, Secure (when using HTTPS), and SameSite.
- Invalidate session tokens on logout and when sessions expire.

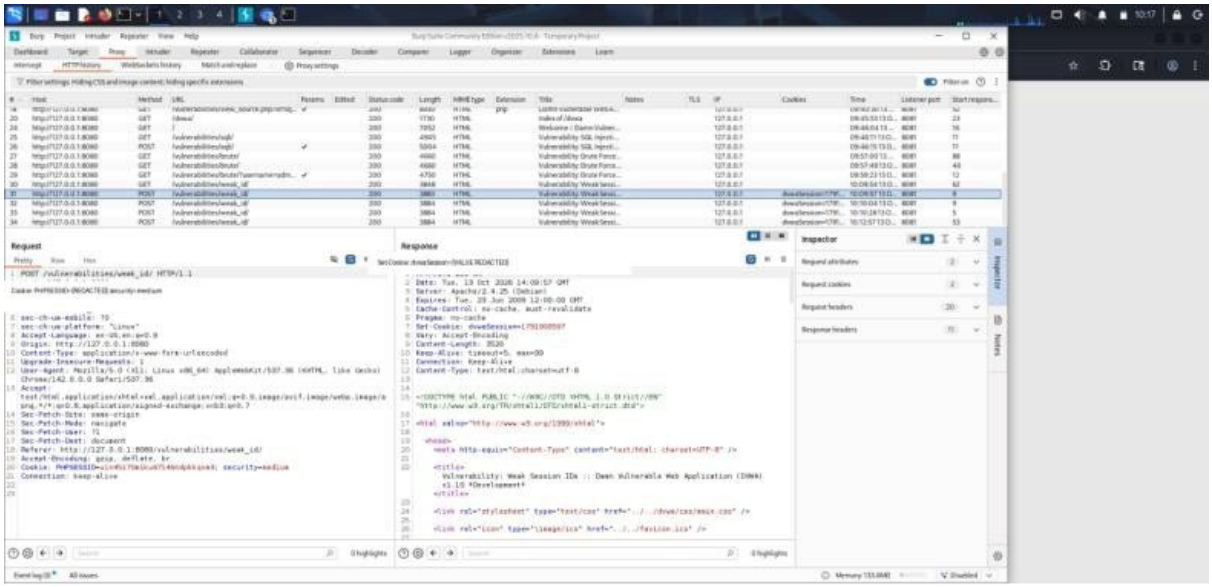


Figure 9. Weak Session ID Value Comparison

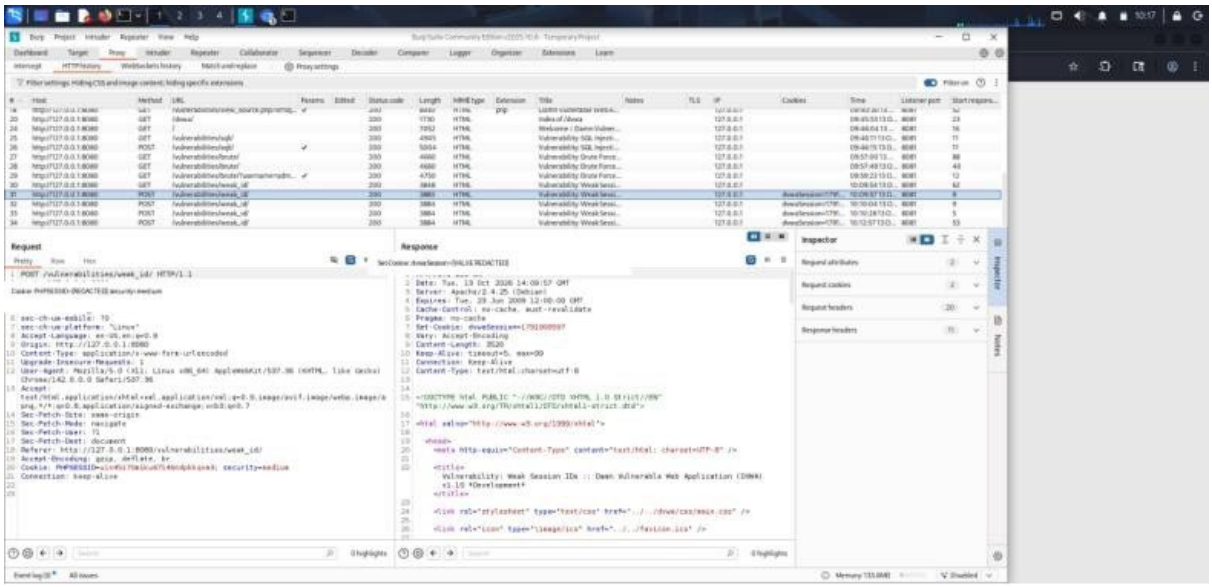


Figure 10. Weak Session ID Value Comparison – Additional Request

8. Attack-Chain Analysis

An attack chain connects separate weaknesses into a demonstrated sequence that leads to a security impact. Based on the supplied evidence, a complete multi-stage chain is not established. The confirmed SQL injection behavior is a standalone finding. The Brute Force and Weak Session IDs pages provide additional attacksurface observations, but the evidence does not link them to the SQL injection result or demonstrate successful account compromise.

Evidence-supported sequence

- Identify the local DVWA application and relevant pages.
- Capture normal requests and establish baseline behavior in Burp Suite.
- Change the SQL user-ID input and replay the request.
- Observe multiple records returned for the Boolean expression input.
- Document authentication and session-token observations separately.

This is best described as a controlled test sequence rather than a confirmed attack chain. Additional evidence would be required to demonstrate an exploitable link between findings.

9. Risk Assessment

Observation	Evidence status	Potential impact	Suggested priority
SQL query logic can be altered	Confirmed in local DVWA Medium	Disclosure of multiple records from the tested lookup	High in lab; validate before rating real systems
Credentials Observed in Possible exposure Medium design **placed in URL** captured request in history and logs concern **query string**			
Dvwa Session value changes after Generate	Observed; predictability unproven	If predictable, session impersonation may be possible	Needs further validation
Invalid ID Observed normal No vulnerability Informational **returns no** behavior established **matching record**			

10. Remediation Recommendations

10.1 SQL injection

- Replace SQL string concatenation with parameterized/prepared statements.
- Validate user IDs as integers on the server side and reject unexpected formats.
- Apply least-privilege database permissions and return only the fields required.
- Add regression tests using valid, invalid, and Boolean-logic input cases.

10.2 Authentication handling

- Submit credentials in a POST body over HTTPS rather than a URL query string.

- Implement rate limits, login throttling, secure password storage, and multifactor authentication as appropriate.
- Avoid exposing detailed authentication failure information.

10.3 Session management

- Use secure, unpredictable session identifiers generated by a cryptographically secure source.
- Set HttpOnly, Secure, and SameSite cookie attributes as applicable.
- Rotate identifiers after login and privilege changes; expire and invalidate them correctly.
- Test token unpredictability before concluding that a weak-session vulnerability exists.

11. Conclusion

The Week 8 exercise provided practical experience in attack-surface mapping, HTTP request inspection, request replay, parameter tampering, and evidencebased risk analysis. The clearest confirmed finding was SQL injection behavior in the local DVWA Medium configuration, where a modified user-ID value caused multiple records to be returned. The Brute Force and Weak Session IDs pages revealed areas that deserve secure-design review, but the available screenshots do not establish successful brute forcing or exploitable session prediction.

The exercise reinforces the importance of parameterized database queries, safe credential submission, secure session-token generation, and accurate reporting. Testing remained within the authorized local lab environment.

12. Evidence Index

- Figure 1. Brute Force Page Assessment

- Figure 2. Capturing DVWA HTTP Requests Using Burp Suite
- Figure 3. Baseline POST Request and Response in Burp Repeater
- Figure 4. Invalid User ID Parameter Validation Using Burp Repeater
- Figure 5. Valid User ID Testing Using Burp Repeater
- Figure 6. SQL Injection Demonstration at DVWA Medium Security Level
- Figure 7. Attack Surface Mapping – Brute Force Login Functionality
- Figure 8. Normal Input Result
- Figure 9. Weak Session ID Value Comparison
- Figure 10. Weak Session ID Value Comparison – Additional Request

13. Internship Attribution

Program: DG Interns Hub – Cybersecurity Internship

Week: 8 – Advanced VAPT: Attack Chain & Full Exploitation Project

Submitted by: Varsha Kammari, Cybersecurity Department, DRK College of Engineering and Technology

Testing scope: local DVWA training application only.